

Digital Privacy Agreement Audit

Team Members: Tirth Laheri, Jay Beladiya

Overview of Services Analyzed:

Company	Company Type
Amazon	Financial/Ecommerce
Paypal	Financial
Discover	Financial
Robinhood	Financial Services
Meta	Social Media
Netflix	Entertainment
Riot Games	Gaming
Ubisoft	Gaming
Google	Email/Communication
Microsoft	Email/Communication
USPS	Government Services

Key Findings:

- 1. Companies that collect more sensitive data don't necessarily explain it more clearly.** The financial companies (Amazon's payment features, PayPal, Discover) collect the most sensitive information like government ID numbers, bank details, credit history, which makes sense given the industry. But Discover's notice, which is required by federal banking law, is actually the clearest and easiest to read of all nine, laid out as a simple table. Amazon collects less sensitive data overall but explains it in long paragraphs with no comparable table.
- 2. Companies word their "we don't sell your data" promises very differently.** Google and Riot Games both state clearly that they don't sell personal information, using the exact legal terms from privacy laws. Netflix goes further and is upfront that some of its own marketing practices *do* count as a "sale" or "sharing" under California's privacy law. Meta and Amazon describe similar advertising practices but avoid using those legal terms, which makes it harder for a reader to tell whether the practice falls under their opt-out rights or not.
- 3. Every company gives users some way to access, fix, or delete their data but they don't all say so with the same confidence.** Riot Games, Ubisoft, Netflix, Google,

and Microsoft list these as clear rights, often naming the exact law behind them. While Amazon and Meta both provide similar tools, they have used more subdued language in defining the right, stating that you can use the tools “to the extent required by applicable law”.

4. **Some companies make it easy to manage your privacy settings; others make you hunt for them.** Ubisoft put all the settings (ads, cookies, newsletter) in one place, while Amazon, Microsoft and Meta split all these settings across different pages which make it more work for someone who is trying to actually change all these settings.
5. **Government agencies take privacy in a totally different light as compared with business corporations.** USPS, for instance, gathers far less customer data for marketing and profiling purposes as commercial businesses are doing it; besides, USPS is very clear they do not sell customer’s personal information for money making. Its privacy statement focuses on being in line with the requirements of Privacy Act, enhancing privacy and data security through information technology and making data processing activities open to customer inspection, rather than focusing on promotional tools and product personalization features.
6. **Robinhood is one instance where regulatory guidelines can quite a bit affect privacy policies.** It has implemented robust security mechanisms, including multi-factor login, identity confirmation and user guide about data processing but consumers are deprived of some key rights like data removal and portability because financial laws mandate the retention of customer records for the purposes of prevention of fraud and legal compliance.
7. **Only one company publishes numbers.** Ubisoft’s privacy policy includes an actual metrics table in the document. For example, “Right to deletion”: Requests made in California - 2718, Requests denied: 1, Average response time: 17.5 hours. Netflix also shows the metrics but not in the document as the privacy policy.

Regulatory Compliance Assessment

Privacy agreements were checked against major requirements specified in the General Data Protection Regulation (GDPR), the California Consumer Privacy Act/California Privacy Rights Act (CCPA/CPRA), and the Virginia Consumer Data Protection Act (VCDPA) to ensure these policies were open, that they provided proper consumer rights, explained data processing methods and were compliant with regulations.

- **Riot Games and Ubisoft** did the best overall. Both explain exactly which legal basis they use for each type of data processing, list every right the user has and also name a contact for any complaints.
- **Netflix, Google, and Microsoft** were close behind. Netflix uses precise legal language for its own practices, Google calls out extra protections for health data required by Washington and Nevada state law, and Microsoft says its privacy rights apply “regardless of your location” — stronger than the usual “rights vary by region” wording most companies use.

- The data management tools provided by **Meta and PayPal** are decent but use vague terminology when describing your legal rights depending on which region you belong to. In addition, PayPal mentions that the credit agencies used by them can further distribute your data to other companies for checking which is a serious weakness in the principle of data being confined to a closed loop.
- **Amazon** often uses more cautious language when referring to its privacy policies than what its actual tools imply.
- **Robinhood** also shows very good compliance with regulations as it clearly records the collection, sharing, and protection of financial information and complies with financial regulations such as the Gramm-Leach-Bliley Act (GLBA). Compared to other services, there are still limitations in the privacy rights for Robinhood due to mandatory record retention requirements.
- **USPS** differs from every commercial organization analyzed because it operates under the Privacy Act rather than consumer privacy laws such as the CCPA or VCDPA. Its policy emphasizes data minimization, secure handling of personal information, and federal cybersecurity protections instead of advertising preferences or commercial data sharing.

Challenges Identified During the Audit

The audit highlighted some common difficulties encountered by organizations in all of the different sectors:

- Privacy policies usually include a lot of legal jargon that makes them difficult for lay users to understand.
- Information related to cookies, preferences for advertising, and data-sharing is often scattered across multiple pages.
- Several organizations simply give generic information about sharing data with third parties, without stating specific categories of how the data will be shared.
- Variations in privacy laws from country to country mean that it is not always possible to give the same privacy rights to everyone.
- Financial Institutions/Governments Privacy rights matter though they need to be balanced with other legal obligations for storage of records over a certain period.

Recommendations for Improvement

- The companies should be more transparent with privacy policies, by decreasing the legal travel language included and describing their users' rights in as clear and simple language as possible. Avoiding legal language; structuring the policy with summaries; headings and concrete examples would be very helpful and would inform users of the company's collection and usage of personal data without attorney interpretation.
- Allow users to control their privacy website-wide through a single privacy dashboard, rather than making users navigate through multiple privacy pages.
- Users could control cookie settings, marketing preferences, privacy service, and privacy requests through the same web page. Robinhood and other finance agencies

should be more transparent about the limits on the privacy rights caused by data retention laws and fraud prevention laws. Offering a simple explanation of the financial laws would clarify the situation for the user and make them more aware of why some requests cannot be granted, like those to delete financial records.

- USPS and other government agencies could offer a simple and familiar structure at the beginning and more straightforward language used today by organizations that have implemented the days' must contemporary non-regulatory privacy mandates, that include the GDPR and CCPA. Though these agencies focus on security and legality, readability would transmit privacy data more directly to all readers. All entities should lead the way by increasing transparency over data sharing, data retention and automation.
- Privacy policies should make clear the sharing of data with third parties, determine the existence of retention periods for specific types of data, on the timespan of this data and the use of automated decisions. Regular presentation of such information in a comparative and user-friendly manner would Quite a bit build customer trustworthiness and would reflect increased responsible data management.

Lessons Learned

- **Finding a middle ground between privacy and commercial requirements:** In any industry, companies of all sizes must strike a balance between business goals, regulatory compliance requirements and user's personally identifiable information.
- **Privacy priorities by industry:** Financial companies are mainly concerned with fraud detection and regulation compliance, Technology and entertainment companies are concerned with personalization and user experience, whereas Government agencies are more interested in statutory obligation compliance and maintaining public confidence.
- **Privacy rights are getting standard:** Eight out of the eleven companies [indicated that] users have the right to access, update, or delete their personal data. This is either available in the privacy policy or through interaction with the service, but not throughout all companies.
- **Clear communication is as valuable as effective privacy protections :** A number of firms provide extensive privacy regulations, but do so in language that is difficult to understand and often difficult to interpret.
- **Transparency engenders trust:** Companies that simply and transparently provide information on how they collect, share, keep, and protect user data are more likely to earn trust than those that offer a cryptic, jargon-laden privacy statement.
- **Areas to be improved:** User trust can still be further enhanced if organizations can: simplify the privacy policies into common version, make privacy options available in one-stop-shop approach, and introduce more clear and open trading of information, retention periods, and use of auto-decision.

Overall Comparison Summary

The comparison showed that organizations from different industries prioritize privacy in different ways.

- Financial organizations were most stringent as far as security and regulatory compliance were concerned, yet their limited privacy rights were often the result of legal requirements.
- Technology and gaming businesses have normally offered user privacy the most extensive set of controls and their businesses have also internationalized in a compliant manner by adhering to the privacy regulation.
- Entertainment companies have made it clear and open how they use advertising and recommend it to people.
- Government agencies put their efforts mainly upon data minimization, statutory compliance, and cybersecurity without putting the commercial aspect of the use of private data into consideration.
- In every business, there are still the major possibilities to increase transparency and readability.